29 Improving your application's security

This chapter covers

- Defending against cross-site scripting attacks
- Protecting from cross-site request forgery attacks
- Allowing calls to your API from other apps using CORS
- Avoiding attach vectors such as SQL injection attacks

In chapter 28 you learned how and why you should use HTTPS in your application: to protect your HTTP requests from attackers. In this chapter we look at more ways to protect your application and your application's users from attackers. Because security is an extremely broad topic that covers lots of avenues, this chapter is by no means an exhaustive guide. It's intended to make you aware of some of the most common threats to your app and how to counteract them, and also to highlight areas where you can inadvertently introduce vulnerabilities if you're not careful.

TIP I strongly advise exploring additional resources around security after you've read this chapter. The Open Web Application Security Project (OWASP) (www.owasp.org) is an excellent resource. Alternatively, Troy Hunt has some excellent courses and workshops on security, geared toward .NET developers (https://www.troyhunt.com).

In sections 29.1 and 29.2 you'll start by learning about two potential attacks that should be on your radar: cross-site scripting (XSS) and cross-site request forgery (CSRF). We'll explore how the attacks work and how you can prevent them in your apps. ASP.NET Core has built-in protection against both types of attacks, but you have to remember to use the protection